

PsyClick: Clinical Decision Support System for Detecting Single-Session Psychomotor Disturbances via EWMA-Based Multivariate Analysis of Keystroke and Cursor Dynamics

by

Ayaay, Martonie Loreign L.
Ballano, Denise Nicole M.
Huertas, Lana Denise R.
Tablate, Judea Ann C.

Security Evaluation Report

FEU Institute of Technology
July 2026

©2026 Ayaay, Martonie Loreign L., Ballano, Denise Nicole M.,
Huertas, Lana Denise R., Tablate, Judea Ann C.
All Rights Reserved

1. Purpose and Scope

This document is the Security Evaluation Report for PsyClick Secure, required under the CS0029 Final Project Specification (Section IV.B, item 4). It summarizes the vulnerability assessment, risk analysis, security-controls review, and security recommendations for the psyclick-secure application, drawing on the detailed companion Risk Assessment Report and Security Testing Report.

Component	Requirement	Evidence / Status
Vulnerability Assessment	Required	Static analysis and dependency audit completed; dynamic scanning remains external work.

Risk Analysis	Required	Risk matrix and treatment mapping documented; full register in the Risk Assessment Report.
Security Controls Review	Required	Implemented controls and remaining limitations documented below.
Security Recommendations	Required	Release prerequisites and future enhancements documented below.

2. Vulnerability Assessment

Static Application Security Testing (SAST) with bandit across all ten backend modules (4,094 lines) returned 0 High-severity findings, 13 Medium findings (all rule B608, string-based query construction), and 15 Low findings (all rule B110, broad try/except/pass). The 13 Medium findings were manually reviewed and confirmed as false positives: the interpolated fragments are static, internally-chosen query shapes, while every caller-supplied value is passed through parameterized bind parameters.

Software Composition Analysis (npm audit) on the frontend initially reported 16 advisories (1 critical, 9 high, 5 moderate, 1 low). Non-breaking remediation (npm audit fix) reduced this to 8, all confined to build-time devDependencies (Electron/Vite/electron-builder). Zero advisories remain in the shipped runtime dependencies.

A ten-scenario conceptual/simulated penetration test was walked through against the source, each mapped to an expected control. Dynamic HTTP/penetration testing against a running deployment remains an external deliverable.

3. Risk Analysis

Risks were scored by likelihood and impact, inherent versus residual. After the implemented controls, no risk scores Critical residual; the highest residual items are the absence of at-rest encryption for the live database (R-06) and the absence of multi-factor authentication (R-16), both carried forward as pre-deployment recommendations. The complete 16-item register, scoring model, and treatment plan are in the companion Risk Assessment Report.

Risk	Likelihood	Impact	Mitigation
SQL injection	Medium	High	Parameterized queries, input validation
Data breach	Medium	High	DPAPI-protected exports/backups, encryption policy
Account hijacking	Medium	High	scrypt, lockout, session expiry; MFA recommended
Brute-force / credential stuffing	Low (post-mitigation)	High	Lockout plus threshold-based intrusion monitor
Malware / ransomware	Medium	High	Least privilege, endpoint controls, encrypted backups

4. Security Controls Review

The implemented controls map to the information-assurance objectives as follows:

Security Objective	Control	PsyClick Implementation
Confidentiality	Encryption and least privilege	scrypt credentials; DPAPI exports/backups; RBAC; ownership scope
Integrity	Hashing and transactions	SHA-256 backup digests; hash-chained audit log; SQLite

		transactions; parameterized SQL
Availability	Backup system	Encrypted backup creation and restore validation; RPO/RTO policy to be exercised operationally
Authentication	Unique identity and secure sessions	Server-side bearer sessions, 12-character policy, lockout, idle/absolute expiry, revocation
Authorization	RBAC and record-level checks	Admin, clinician, auditor roles; ownership-scoped clinical queries
Accountability	Audit logs	Login, denial, consent, access, export, configuration, backup, and restore events

A security regression suite of ten tests covers password policy, session revocation, consent fail-closed behavior, audit-chain tamper detection, encrypted backup/restore validation, and the intrusion monitor. Nine pass on any platform; the tenth exercises Windows DPAPI backup encryption and passes on the Windows target.

5. Security Recommendations

- Implement multi-factor authentication for administrator accounts, then extend to all roles.
- Add field-level (or full-database) encryption at rest for the live SQLite database, using a deterministic blind-index scheme for lookup fields (risk R-06).
- Commission an authorized dynamic penetration test against a running deployment.
- Complete a clean installation on an independent workstation and record the evidence.
- Collect signed User Acceptance Test forms and perform a live restore drill.
- Schedule a major-version upgrade of the Electron/Vite/electron-builder toolchain to clear the remaining build-time advisories.

6. Approval

Name	Signature
Ayaay, Martonie Loreign L.	
Ballano, Denise Nicole M.	
Huertas, Lana Denise R.	
Tablate, Judea Ann C.	